

Materiale per tracce di Sistemi e Reti

Versione più semplice

NB questa è la versione dettagliata

è più dettagliata e complessa di quanto serve in esame, ho prodotto una versione più semplice che dovrebbe essere ancora reperibile.

L'approccio consigliato è:

- *in prima istanza, per identificare carenze e imparare qualche concetto addizionale esaminare questa versione dettagliata, tenendo presente che è **oltre il nostro livello di dettaglio e programma**.*
- *utilizzare poi la più semplice, richiedetela se non già condivisa*

0. Idea di base

Nell'esame di Stato non conviene progettare ogni volta tutto da zero.

Conviene conoscere quasi a memoria:

- una procedura di soluzione;
- una reference architecture a 2 livelli;
- una reference architecture a 3 livelli;
- gli elementi ricorrenti: VLAN, DMZ, firewall, Wi-Fi interno/guest, VPN, cloud, server interni, rete di management, monitoraggio, sicurezza, backup, accesso remoto.

1. Contesto

Le architetture per cui vengono forniti schemi di riferimento sono relative ai seguenti requisiti:

reference architectures di sistemi e reti, cioè architetture realistiche che includano tutti gli elementi che ricorrono più spesso nelle reti di organizzazioni del mondo reale. Le reference architectures vanno definite ovviamente in ottica di traccia di esame di stato ma devono essere il più possibile realistiche e includere tutti gli elementi che ricorrono più spesso nelle reti di organizzazioni reali.

Va creata almeno una versione per il 2 layers e una per il 3 layers.

Le organizzazioni per le quali si crea la rete devono avere tutti i ragionevolmente possibili casi di connettività e di sicurezza.

Un esempio di elementi da includere: - connettività wifi di interni e ospiti
- server esterni: almeno un server WEB e un server che espone endpoints REST e SOAP on-site
- server interni: DBMS, sistema SAP, sistema di business custom, applicativo/server documentale dedicato a files con dati aziendali riservati accessi-

bili solo al management, MongoDB per gestione documenti generale, relativa a documenti non altamente confidenziali accessibili a normali dipendenti secondo RBAC

- connettività da ufficio secondario ubicato in line-of-sight a 600 metri dalla sede considerata
- un'altra sede principale in un'altro continente, questa sede deve connettersi in VPN site-to-site
- tutti e soli i dipendenti di livello manageriale devono avere accesso per lavorare remotamente
- deve essere prevista e specificata una rete di gestione
- l'organizzazione' espone servizi pubblici oltre che on-site, su un fornitore cloud, usando l'approccio serverless, alcuni di questi servizi per la loro implementazione invocano alcuni dei servizi implementati on-site citati in precedenza
- specificare come viene implementata la rete di management e perchè
- cercare di includere IDS/IPS integrati con NMS
- l'organizzazione fa anche, internamente, nella propria rete (anche se normalmente si tende a preferire il cloud per elasticità Etc.), delle elaborazioni big data utilizzando un sistema distribuito di circa 10 nodi, la rete deve supportare adeguatamente queste elaborazioni e i loro requisiti di trasmissione di grandi quantità di dati in tempi rapidi

2. Processo di soluzione della traccia

2.1 Lettura iniziale della traccia

Leggere la traccia cercando subito:

- sedi presenti;
- numero di utenti;
- reparti aziendali;
- server interni;
- servizi pubblici esposti su Internet;
- vincoli di sicurezza;
- presenza di Wi-Fi;
- presenza di sedi remote;
- presenza di cloud;
- richieste di scalabilità;
- richieste di prestazioni elevate;
- dati riservati;
- accesso remoto dei dipendenti.

Quanto segue funzionerebbe per l'autore di queste annotazioni se fosse uno studente, potrebbe non funzionare per voi, definite il vostro approccio, non andate a casaccio:

- La traccia va letta almeno tre volte, in totale leggerla 5 volte non è esagerato.

- Prendere decisioni (cioè fare scelte tecniche o addirittura calcoli) quando si ha una comprensione sufficiente della traccia (letta e ragionata serenamente a sufficienza).
- “He who walks in a hurry takes the wrong road” detto Inglese
- “la gatta frettolosa fece i figli ciechi” (mia nonna :-)
- Etc. - Quanto sopra non implica attendere inutilmente: già dalla prima lettura si può cominciare ad annotare punti rilevanti o anche fissare dettagli tecnici, ad ogni lettura si alza il livello di comprensione e la possibilità di fare scelte non errate o basate su comprensione errata.

Importante:

- distinguere ciò che è obbligatorio da ciò che è una scelta progettuale.
- a fronte di alternative più o meno equivalenti valutare complessità/vantaggi, sicurezza di svilupparla correttamente Etc.

2.2 Identificazione delle zone di rete

Una rete aziendale realistica non è una sola LAN piatta.

Le zone più frequenti sono:

- collegamenti WAN;
- LAN utenti;
- LAN management;
- VLAN server interni;
- VLAN management;
- VLAN guest Wi-Fi;
- DMZ pubblica;
- collegamenti VPN;
- rete ufficio secondario.
- VLAN IoT/stampanti/dispositivi tecnici;
- rete backup;
- rete big data / elaborazione distribuita;
- cloud VPC/VNet;

L'ultimo elemento, cloud VPC/VNet, non è stato esaminato nel nostro programma.

Cloud VPC/VNet è una rete privata virtuale creata dentro un cloud provider, è l'equivalente cloud di una rete aziendale interna, ma realizzata su infrastruttura cloud.

AWS la chiama VPC, cioè Virtual Private Cloud, Azure la chiama VNet, cioè Virtual Network, Google Cloud usa il termine VPC.

Serve per organizzare e proteggere le risorse cloud, ad esempio:

- server virtuali;
- database cloud;
- funzioni serverless;

- API gateway;
- bilanciatori di carico;
- subnet pubbliche e private;
- regole firewall;
- collegamenti VPN verso la sede aziendale.)

2.3 Scelta tra architettura a 2 layers e 3 layers

Usare una rete a 2 layers quando:

- la sede è medio-piccola;
- gli armadi di rete sono pochi;
- il traffico interno è significativo ma non enorme;
- access e distribution possono essere accorpati;
- si vuole una soluzione più semplice da spiegare.

Usare una rete a 3 layers quando:

- la sede è grande;
- ci sono molti switch access;
- ci sono più edifici o piani;
- il traffico interno è elevato;
- ci sono server farm, big data, storage, backup;
- serve alta disponibilità;
- è utile separare chiaramente access, distribution e core.

Il modello gerarchico access/distribution/core è una struttura classica del **campus LAN**:

- l'access collega gli endpoint,
- la distribution aggrega gli switch di accesso - il core collega, ad alte prestazioni, le diverse aree.

2.4 Definizione delle VLAN

Una possibile struttura che include le tipologie di reti citate è la seguente

VLAN	Nome	Uso
10	MANAGEMENT	gestione switch, AP, firewall, server
20	ADMIN	amministrazione, segreteria, uffici generali
30	MANAGEMENT_USERS	risidenti / management aziendale
40	DIPENDENTI	normali dipendenti
50	GUEST_WIFI	ospiti, solo Internet
60	SERVER_INTERNI	server applicativi interni
70	DB	database interni

VLAN	Nome	Uso
80	DOCUMENTALE_RISERVATO	documenti riservati management
90	DOCUMENTALE_GENERALE	documenti / documenti non altamente confidenziali
100	SAP_ERP	SAP o ERP aziendale
110	CUSTOM_BUSINESS	applicativo aziendale custom
120	DMZ_ON_PREMISE	servizi pubblici on-site
130	BIG_DATA	cluster distribuito 10 nodi
140	BACKUP_STORAGE	backup, NAS, repository
150	IOT_PRINT	stampanti, IoT, dispositivi tecnici
160	WIFI_CORPORATE	dispositivi aziendali Wi-Fi
170	UFFICIO_SECONDA	seconde secondaria a 600 m
180	VPN_REMOTE_MANAGER	accesso remoto dei soli manager

Traccia esame

Normalmente avrete molte meno reti, ma sono molto probabili:

- una (V)LAN utenti
- una (V)LAN server
- una (V)LAN DMZ
- una (V)LAN management
- una (V)LAN guest Wi-Fi (se Wi-Fi presente)

Più altre reti eventualmente specifiche alla traccia.

Al momento esiste una versione semplificata di queste annotazioni limitata a queste reti di base.

2.5 Regola fondamentale sui permessi

Non tutte le VLAN devono parlare con tutte le altre.

Schema consigliato:

Da	Verso	Permesso
Dipendenti	Internet	consentito filtrato
Guest Wi-Fi	Internet	consentito, isolato
Guest Wi-Fi	LAN interna	negato
Dipendenti	MongoDB	consentito secondo RBAC
	documentale generale	
Dipendenti	documentale riservato	negato
Management	documentale riservato	consentito

Da	Verso	Permesso
Management	SAP / ERP	consentito
Management	VPN remota	consentito con MFA
Normali dipendenti	VPN remota	negato
Server applicativi	DB	consentito solo su porte necessarie
DMZ	DB interni	vietato direttamente, salvo API controllate
Cloud serverless	API on-site	consentito tramite canale sicuro/API gateway/VPN
Management network	apparati	consentito solo da postazioni amministrative
Big data nodes	tra loro	consentito ad alta banda
Big data	DB/Storage	consentito solo dove necessario

3. Reference architecture a 2 layers

3.1 Quando usarla

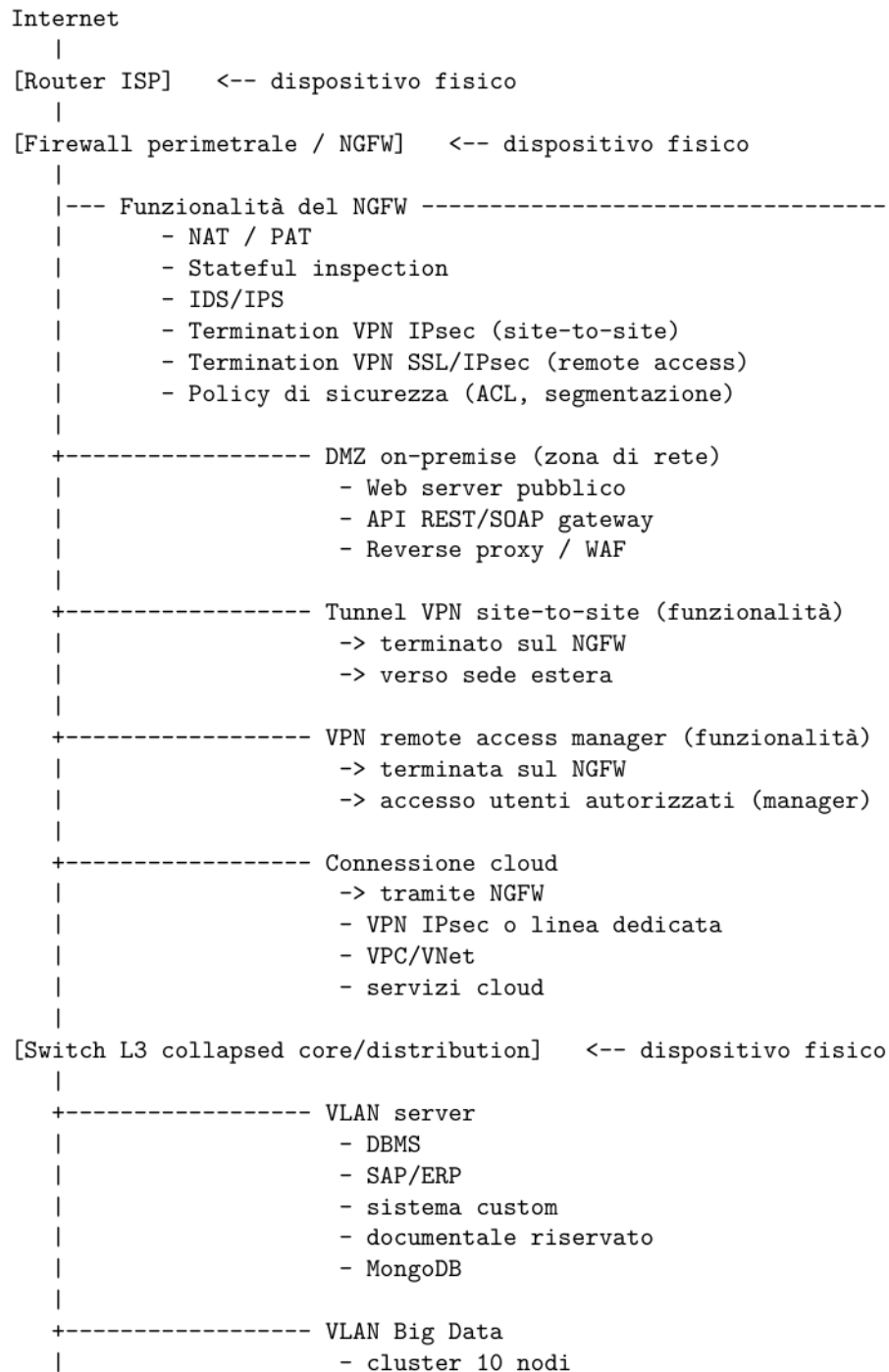
Questa architettura è adatta a una sede principale di dimensione media, con:

- alcuni switch di accesso;
- server interni;
- DMZ;
- Wi-Fi aziendale e guest;
- collegamento a ufficio secondario vicino;
- VPN verso sede estera;
- collegamento cloud;
- cluster big data interno di circa 10 nodi.

In una rete a 2 layers si hanno:

- Access layer: switches a cui si collegano utenti, AP, stampanti, telefoni, dispositivi;
- Collapsed core/distribution: uno o più switches Layer 3 che svolgono sia il ruolo di core sia di distribution, aggregando tutto il traffico e gestendo il routing tra le VLAN (inter-VLAN routing). Nelle reti reali questi dispositivi sono normalmente presenti in coppia per garantire alta disponibilità, con configurazioni di ridondanza che possono essere attiva/passiva oppure attiva/attiva a seconda delle tecnologie utilizzate.

3.2 Schema logico a 2 layers



- “VPN site-to-site”
- “VPN remote access”

sono **servizi logici**, non oggetti fisici.

Nella pratica reale:

- sono implementati su:
 - firewall/NGFW (caso più comune)
 - router enterprise
 - oppure appliance dedicata (meno comune oggi)
-

2. Dove “vivono” realmente le VPN Nel tuo schema:

- entrambe sono terminate sul **firewall perimetrale / NGFW**
- quindi:

VPN = funzionalità interna del firewall

3. Differenza funzionale tra le due VPN VPN site-to-site

- collega due reti
- trasparente agli utenti
- sempre attiva (tunnel permanente)

VPN remote access

- collega singoli utenti
 - autenticazione (MFA tipicamente)
 - accesso selettivo (solo manager nel nostro caso di esempio)
-

4. Quando diventano dispositivi separati È utile sapere che esistono eccezioni:

- grandi aziende:
 - VPN concentrator dedicati
 - soluzioni tipo Cisco ASA/Firepower cluster, Fortinet, Palo Alto
 - ambienti cloud:
 - gateway VPN gestiti (AWS VPN Gateway, Azure VPN Gateway)
-

Formulazione breve

- Router ISP e firewall sono dispositivi fisici
- DMZ è una zona di rete
- VPN site-to-site e remote access sono funzionalità del firewall (non dispositivi)
- Switch L3 realizza routing interno (inter-VLAN)
- Switch access collegano dispositivi finali
-

Link radio PTP è un collegamento fisico tra sedi

3.3 Spiegazione dei componenti

Il firewall perimetrale / NGFW separa Internet, DMZ, LAN interna, VPN e cloud.

Deve applicare policy diverse per ogni zona.

Può includere funzioni IDS/IPS, filtro applicativo, controllo URL, logging e VPN.

La DMZ contiene i servizi raggiungibili dall'esterno:

- web server pubblico;
- gateway API REST/SOAP;
- reverse proxy;
- WAF.

I database non devono stare normalmente in DMZ. Devono stare in una rete interna più protetta.

In generale i server in DMZ devono poter comunicare con server "interni" solo sulle porte strettamente necessarie.

Gli switch Layer 3 centrali fanno routing inter-VLAN, oppure il routing inter-VLAN può essere demandato al firewall.

- il firewall controlla i passaggi tra zone con diverso livello di sicurezza; - il routing interno tra VLAN con lo stesso livello di sicurezza è gestito dallo switch Layer 3 per motivi di prestazioni; quando invece le reti appartengono a domini di sicurezza differenti (es. utenti vs server, LAN vs DMZ), il traffico deve essere filtrato dal firewall; - le ACL sugli switch Layer 3 limitano il traffico interno non necessario, realizzando controlli semplici e locali senza sostituire le funzionalità di sicurezza avanzata del firewall.

3.4 VLAN principali nella rete a 2 layers

Nella traccia probabilmente ne avrete meno, la versione semplificata di queste note ne tratta meno

```
VLAN 10  Management
VLAN 20  Amministrazione
VLAN 30  Management aziendale
VLAN 40  Dipendenti
VLAN 50  Guest Wi-Fi
VLAN 60  Server applicativi
VLAN 70  Database
VLAN 80  Documentale riservato
VLAN 90  MongoDB documentale generale
VLAN 100 SAP/ERP
VLAN 110 Applicativo custom
VLAN 120 DMZ on-premise
VLAN 130 Big Data
VLAN 140 Backup/Storage
VLAN 150 IoT/Stampanti
VLAN 160 Wi-Fi corporate
VLAN 170 Ufficio secondario
VLAN 180 VPN manager
```

3.5 Wi-Fi

La rete Wi-Fi deve usare almeno due SSID:

SSID	VLAN	Accesso
Azienda-Corporate	160	LAN aziendale secondo ruolo
Azienda-Guest	50	solo Internet
Azienda-Management, opzionale	30	solo manager autorizzati

Il Wi-Fi guest non deve poter accedere a server interni, stampanti aziendali, apparati di rete o management network.

Puntualizzazione

Gli access point aziendali solitamente sono collegati agli switch access tramite trunk 802.1Q.

Si utilizza il trunking perchè normalmente un access point aziendale gestisce più reti Wi-Fi (SSID). Normalmente **ogni SSID viene associato a una VLAN**.

Esempio (solo esemplificativo, non allineato a schema precedente) :

- SSID “Aziendale” → VLAN 10

- SSID “Ospiti” → VLAN 20
- SSID “IoT” → VLAN 30

Quindi: **1 access point = più reti logiche (VLAN)**

3.6 Ufficio secondario a 600 metri

Poiché l'ufficio secondario è in line-of-sight a circa 600 metri, si può usare un ponte radio punto-punto.

Schema:

```
Sede principale
|
Switch L3 centrale
|
VLAN trunk verso apparato radio PTP
|
Collegamento radio direzionale 600 m
|
Apparato radio PTP ufficio secondario
|
Switch access ufficio secondario
|
Utenti / AP / stampanti
```

Il ponte radio deve essere:

- cifrato;
- configurato con antenne direzionali;
- monitorato;
- protetto fisicamente;
- preferibilmente ridondato se la continuità è critica.

L'ufficio secondario può usare VLAN proprie oppure estendere alcune VLAN dalla sede principale.

In un progetto scolastico sarebbe più pulito assegnare subnet dedicate all'ufficio secondario e instradarle centralmente.

Se manca il tempo e non si è sicuri al 100%, e **se non è richiesto dalla traccia**, forse non vale la pena addentrarsi in questo.

3.7 Sede principale in altro continente

La sede in altro continente deve collegarsi tramite VPN site-to-site.

Schema:

```
Sede principale Italia
|
Firewall NGFW
|
Internet
|
Tunnel IPsec site-to-site
|
Firewall sede estera
|
LAN sede estera
```

La VPN site-to-site deve cifrare il traffico tra le due sedi.
Le rotte devono permettere solo le comunicazioni necessarie.

Esempi:

- sede estera verso SAP/ERP;
- sede estera verso applicativi business;
- sede estera verso documentale generale;
- eventuale accesso management solo da amministratori autorizzati;
- nessun accesso diretto non necessario ai database.

3.8 Accesso remoto dei soli manager

La richiesta dice: tutti e soli i dipendenti di livello manageriale devono lavorare remotamente.

Soluzione:

- VPN remote access sul firewall o su concentratore VPN;
- autenticazione con MFA;
- gruppo directory “Managers”;
- accesso consentito solo a utenti nel gruppo manageriale;
- profilo VPN separato;
- log degli accessi;
- accesso limitato ai soli servizi necessari.

Schema:

```
Manager remoto
|
Client VPN + MFA
|
Internet
|
Firewall aziendale
|
```

VLAN 180 VPN_REMOTE_MANAGERS

|

Servizi autorizzati:

- SAP/ERP
- documentale riservato
- applicativo custom
- documentale generale

I normali dipendenti non devono avere profilo VPN di accesso remoto.

3.9 Cloud serverless collegato all'on-premise (Opzionale, si va troppo “fuori” dal nostro programma)

L'organizzazione espone anche servizi pubblici su cloud con approccio serverless.

Esempio logico:

Utente Internet

|

API Gateway cloud

|

Funzioni serverless

|

Connessione sicura cloud-on-premise

|

API gateway on-premise / reverse proxy

|

Servizi REST/SOAP interni

|

DB o sistemi aziendali

Il cloud non deve accedere liberamente alla LAN interna. Deve invocare solo endpoint esposti in modo controllato.

Soluzioni possibili:

- VPN site-to-site tra cloud VPC/VNet e sede;
- collegamento dedicato tipo AWS Direct Connect / Azure ExpressRoute;
- API gateway;
- autenticazione forte tra servizi;
- allowlist degli indirizzi sorgente;
- logging centralizzato.

AWS documenta l'uso di Direct Connect e VPN IPsec per connettività ibrida tra ambienti on-premise e cloud; Direct Connect fornisce una connessione dedicata, mentre IPsec VPN può essere usata per cifratura o collegamenti a minore banda. (AWS Documentation)

3.10 Rete di management

La rete di management serve per amministrare:

- switch;
- firewall;
- access point;
- server;
- storage;
- hypervisor;
- apparati radio;
- sistemi di monitoraggio.

Deve essere **separata** dalla rete utenti, logicamente o fisicamente nel caso di ambienti ad alta sicurezza.

Implementazione consigliata:

VLAN 10 MANAGEMENT

|

Accesso consentito solo da:

- postazioni amministratori IT
- jump server / bastion host
- NMS
- server logging/SIEM

|

Accesso negato da:

- guest Wi-Fi
- dipendenti normali
- server pubblici in DMZ
- dispositivi IoT

Motivazione:

- riduce il rischio che un normale client compromesso possa configurare apparati;
- centralizza gli accessi amministrativi;
- consente logging e controllo;
- facilita backup configurazioni;
- permette monitoraggio con NMS.

Jump Server / Bastion Host

jump server *detto anche jump host o bastion host*

macchina usata come punto di accesso controllato per amministrare sistemi che

non sono direttamente raggiungibili dalla rete utente o da Internet.

In termini pratici un jump server è un **server intermedio**

- fortemente protetto
- attraverso il quale passano tutte le connessioni amministrative

Postazione amministratore (admin workstation) → Jump server → Server interni / apparati d

Rete di gestione separata

la rete di management può essere:

- separata fisicamente nei casi più critici (massimo isolamento);
- in alternativa, realizzata come VLAN dedicata su infrastruttura condivisa;
- instradata solo attraverso il firewall, evitando accessi diretti da altre reti;
- accessibile esclusivamente tramite jump server o sistemi di amministrazione controllati;
- protetta con ACL per limitare i flussi strettamente necessari;
- monitorata tramite sistemi di logging, IDS e NMS.

Ovviamente anche con separazione fisica resta necessario:

* controllare accessi * monitorare * limitare i flussi

3.11 IDS/IPS integrati con NMS

SIEM (Security Information and Event Management) Sistema che raccoglie, correla e analizza log ed eventi di sicurezza da più fonti per individuare minacce e supportare monitoraggio e risposta.

IDS (Intrusion Detection System) Sistema che monitora il traffico o i sistemi per rilevare attività sospette o attacchi, generando alert senza intervenire direttamente.

IPS (Intrusion Prevention System) Sistema che analizza il traffico in tempo reale e blocca automaticamente attività malevole o non autorizzate.

Il sistema deve prevedere:

- IDS/IPS sul firewall perimetrale;
- sensori IDS nelle zone interne più critiche;
- NMS per monitoraggio apparati;
- SIEM o sistema di logging centralizzato;
- alert automatici.

Schema:

Firewall / NGFW con IPS

|


```

Log / eventi
|
SIEM / Log server
|
NMS
|
Alert amministratori

```

Possibili punti di controllo:

- traffico Internet-DMZ;
 - traffico DMZ-LAN;
 - traffico VPN-LAN;
 - traffico cloud-on-premise;
 - traffico verso server critici;
 - traffico anomalo nel cluster big data.
-

3.12 Big data interno con 10 nodi

Nei cluster: * il traffico tra nodi è molto elevato * serve bassa latenza

Serve una tipologia di switch adatta a questo contesto.

Switch ToR (Top of Rack)

Switch ToR (Top of Rack)

Switch **di accesso ad alte prestazioni** posizionato in cima a un rack, che collega **direttamente** i server (o nodi) presenti in quel rack. Queste caratteristiche servono per collegare efficacemente:

- * nodi di calcolo
- * storage
- * sistemi ad alta densità

```

[Switch ToR]
|
+-- Server/nodo 1
+-- Server/nodo 2
+-- ...
+-- Server/nodo N

```

Uno switch ToR:

- collega i nodi del cluster
- gestisce traffico est-ovest (tra nodi)
- invia traffico verso il core (nord-sud)
- spesso supporta:
 - link ad alta velocità (10/25/40/100 Gbit)

- aggregazione link (LACP)
- bassa latenza

Differenza rispetto a uno switch access “normale”: - Switch access (uffici):
 * collega PC, stampanti, AP * traffico moderato - Switch ToR: * collega server
 / nodi cluster * traffico molto elevato * prestazioni molto superiori

Approccio cluster big data

Il cluster big data interno genera traffico **elevato** tra nodi e verso storage.
 Il traffico elevato del cluster non deve saturare la rete utenti. Per questo si usa
 una rete dedicata o almeno una VLAN dedicata con uplink ad alta capacità.

Requisiti:

- VLAN o subnet dedicata;
- switch ad alte prestazioni;
- collegamenti almeno 10 Gbit/s per i nodi;
- uplink aggregati verso core/distribution;
- bassa latenza;
- separazione dal traffico utenti;
- accesso controllato ai dati;
- storage adeguato;
- backup separato.

Schema:

```

Coppia switch L3 centrale
|
Switch ToR / aggregation Big Data 10/25 Gbit/s
|
+---- Nodo 1
+---- Nodo 2
+---- Nodo 3
+---- ...
+---- Nodo 10
|
Storage / backup dedicato
  
```

Switch ToR / aggregation Big Data 10/25 Gbit/s significa che:

* collega direttamente i 10 nodi del cluster * gestisce traffico ad alta velocità
 (10/25 Gbit/s) * aggrega il traffico verso lo switch centrale/superiore (core o
 distribution)

4. Reference architecture a 3 layers

4.1 Quando usarla

Questa architettura è adatta a una sede più grande, con:

- molti utenti;
- più piani o edifici;
- server farm interna;
- DMZ;
- cluster big data;
- rete di management;
- alta disponibilità;
- collegamenti WAN;
- cloud ibrido;
- sede estera.

I tre livelli sono:

- access layer;
- distribution layer;
- core layer.

Ottima osservazione: in questo schema le **funzionalità** (VPN, WAF, ecc.) sembrano dispositivi separati. Conviene esplicitare chiaramente la distinzione.

Di seguito una versione migliorata, mantenendo lo stile ASCII ma distinguendo:

- [...] → **dispositivi fisici**
 - (...) → **funzionalità logiche / servizi**
 - blocchi indentati → **zone o sistemi**
-

4.2 Schema logico a 3 layers (con distinzione chiara)

- dispositivi → []
- funzionalità → ()

Internet

|

[Router ISP]

|

[Coppia firewall NGFW in HA]

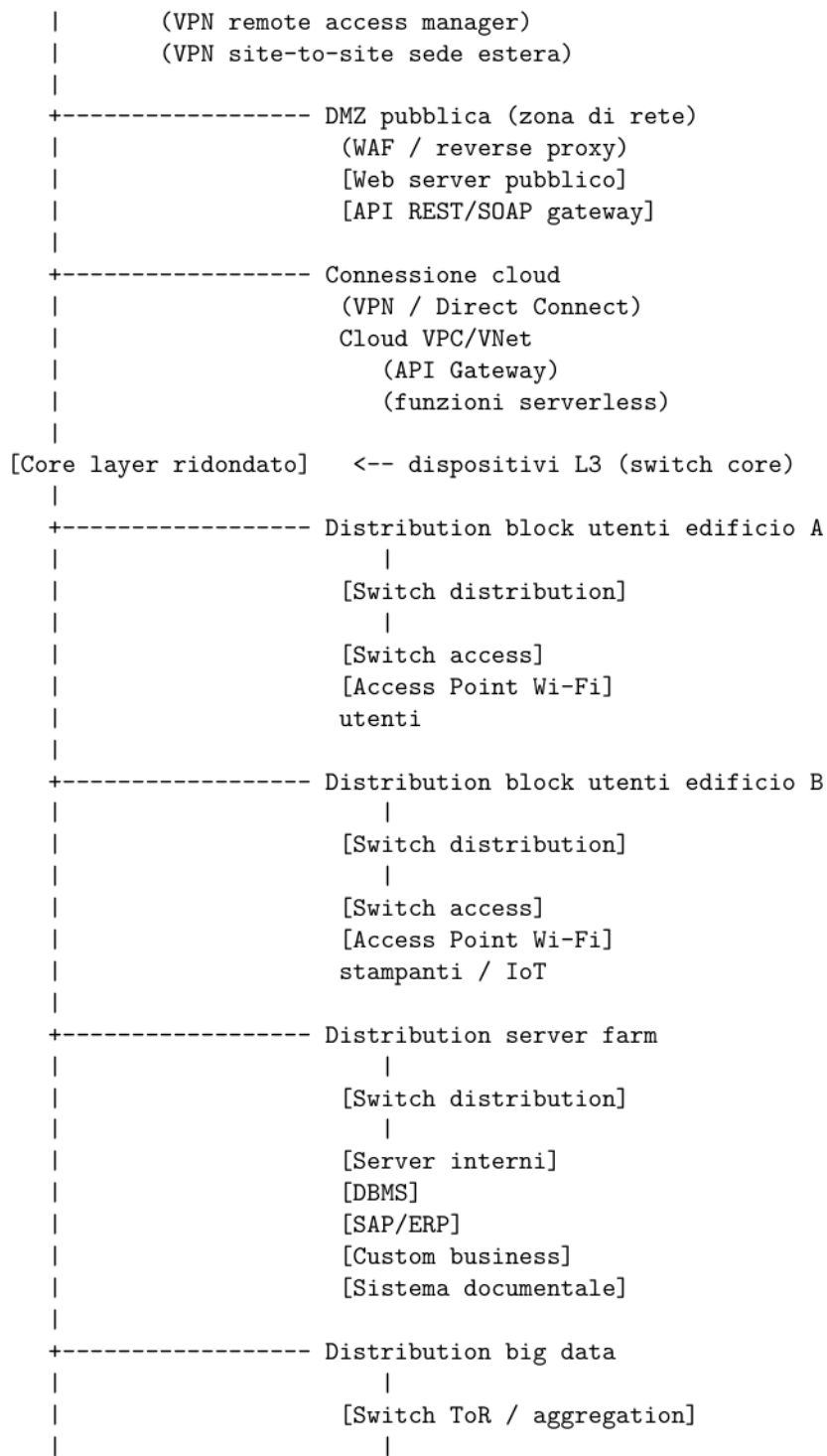
|

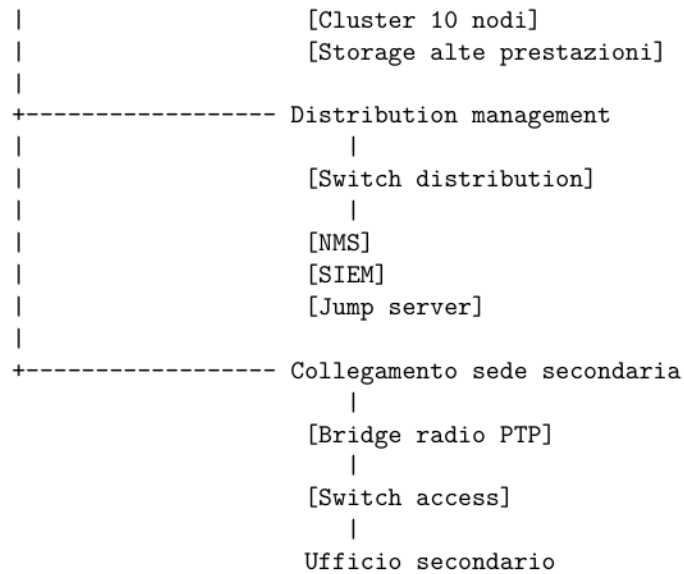
|--- Funzionalità del firewall -----

| (NAT / PAT)

| (Stateful inspection)

| (IDS / IPS)





Puntualizzazioni

(VPN remote access)

(VPN site-to-site)

sono **funzionalità del firewall**, non oggetti separati.

(WAF / reverse proxy)

sono funzionalità/servizi logici (possono essere software o appliance, ma qui trattati come funzione)

4.3 Funzione dei livelli

Access layer

Collega dispositivi finali:

- PC;
- telefoni IP;
- stampanti;
- access point;
- dispositivi IoT;
- client aziendali.

Funzioni tipiche:

- porte access;
- trunk verso AP;
- PoE;

- autenticazione 802.1X se prevista;
- VLAN assignment;
- port security;
- DHCP snooping;
- storm control.

Distribution layer

Aggrega gli switch access.

Funzioni tipiche:

- routing inter-VLAN locale;
- ACL;
- ridondanza;
- aggregazione uplink
- confine dei domini Layer 2;
- policy tra VLAN;
- collegamento verso core.

Core layer

È il backbone veloce della rete.

Funzioni tipiche:

- trasporto ad alte prestazioni;
- ridondanza;
- bassa latenza;
- collegamento tra distribution block;
- collegamento verso firewall, data center, cloud e WAN.

Nel core si evitano regole troppo complesse.

Le policy di sicurezza principali sono applicate su firewall, distribution e sistemi dedicati.

4.4 Server farm interna

La server farm interna contiene:

- DBMS;
- SAP/ERP;
- applicativo business custom;
- server documentale riservato;
- MongoDB documentale generale;
- server autenticazione/directory;

- backup;
- logging;
- NMS;
- eventuale virtualizzazione.

Schema:

```
Distribution server farm
|
VLAN 60  Server applicativi
VLAN 70  Database
VLAN 80  Documentale riservato
VLAN 90  Documentale generale MongoDB
VLAN 100 SAP/ERP
VLAN 110 Custom business
VLAN 140 Backup/Storage
```

Si separano applicazioni, database, documentale, backup e management Etc. perché hanno livelli di criticità diversi.

4.5 DMZ nella rete a 3 layers

Prerequisiti WAF (Web Application Firewall)

Firewall applicativo che analizza e filtra il traffico HTTP/HTTPS verso applicazioni web, proteggendo da attacchi come SQL injection e XSS.

Differenza con firewall generico:

Un firewall tradizionale filtra traffico a livello rete/trasporto (IP, porte), mentre il WAF opera a livello applicativo (Layer 7) comprendendo il contenuto delle richieste web.

Reverse proxy

Sistema che riceve le richieste dei client e le inoltra ai server interni, nascondendone l'identità e gestendo bilanciamento, sicurezza e terminazione TLS.

Soluzione La DMZ deve stare dietro firewall, non direttamente nella LAN.

Schema:

```
text id="z0r6b2" Internet    | Firewall HA    | DMZ    | - WAF
- reverse proxy - web server pubblico - API gateway REST/SOAP
on-premise
```

Flusso tipico verso il web server

text id="5k0vnl" Client → Firewall → WAF → Reverse Proxy → Web Server

Il WAF è posto prima del reverse proxy perché deve essere il primo punto di controllo applicativo: analizza e blocca il traffico malevolo; il reverse proxy, posto a valle, gestisce l'instradamento e il bilanciamento solo delle richieste già filtrate.

text id="wz6ywr" Web Server → Reverse Proxy → WAF → Firewall → Client

Comunicazioni consentite

Da	A	Regola
Internet	WAF/reverse proxy	HTTPS
WAF	reverse proxy	HTTPS interno
Reverse proxy	web server	HTTPS interno
API gateway	servizi interni	solo API necessarie
DMZ	DB interni	vietato o fortemente limitato
LAN interna	DMZ	solo amministrazione controllata
Management	DMZ	solo amministratori tramite jump server

4.6 Cloud serverless nella rete a 3 layers

Prerequisito Serverless (es. Function as a Service)

Modello cloud in cui il codice viene eseguito su richiesta senza gestire direttamente server, con provisioning, scalabilità e gestione demandati al provider.

Benefici e limiti - Consente scalabilità automatica e pagamento a consumo, riducendo tempi e costi operativi, ma introduce limiti come cold start, vincoli di runtime e minore controllo sull'infrastruttura.

Tutorial di base

<https://docs.aws.amazon.com/lambda/latest/dg/welcome.html>

Soluzione Schema:

Internet
|
Cloud provider


```

      |
API Gateway cloud
      |
Funzioni serverless
      |
VPC/VNet privata
      |
VPN / Direct Connect / ExpressRoute
      |
Firewall aziendale
      |
API gateway on-premise
      |
Servizi REST/SOAP interni

```

NB il cloud non deve entrare liberamente nella LAN.

Deve invocare endpoint specifici, autenticati, tracciati e filtrati, utile citare questo nella risposta anche se non si entra nei dettagli, a meno che non lo richieda la traccia.

4.7 Big data nella rete a 3 layers

Nell'architettura a 3 layers il cluster big data deve essere trattato quasi come una piccola server farm ad alte prestazioni.

Considerazioni indipendenti dall'architettura e conoscenze propedeutiche fornite nella precedente sezione relativa al 2-layers, non vengono duplicate qui, consultare tale sezione precedente.

Schema:

```

Core layer
      |
Distribution big data
      |
Switch dedicati 10/25 Gbit/s
      |
10 nodi big data
      |
Storage / data lake interno / backup

```

Scelte consigliate:

- rete dedicata per traffico tra nodi;
- uplink ridondati;
- almeno 10 Gbit/s per nodo;
- storage separato o rete storage dedicata;

- QoS se necessario;
- monitoraggio del traffico;
- accesso degli utenti solo tramite applicazioni o gateway;
- accesso amministrativo solo da VLAN management.

4.8 Management network nella rete a 3 layers

Implementazione consigliata:

```
VLAN 10 MANAGEMENT
|
Distribution management
|
Jump server / bastion host
|
NMS
|
SIEM / log server
|
Backup configurazioni
|
Accesso agli apparati:
- switch access
- switch distribution
- core
- firewall
- AP
- server
- storage
- radio PTP
```

La rete di management può essere:

- in-band, cioè passa sugli stessi apparati ma in VLAN separata;
- out-of-band, cioè usa una rete fisicamente separata per apparati critici.

Nella traccia d'esame consigliabile scrivere almeno, **opportunamente personalizzato**:

“Si prevede una VLAN di management separata, raggiungibile solo da postazioni amministrative e da un jump server. Gli apparati espongono le interfacce di gestione solo su tale VLAN. L'accesso è protetto da ACL, autenticazione forte e logging centralizzato. In ambienti ad alta criticità si può prevedere una rete out-of-band fisicamente separata.”

5. Confronto tra 2 layers e 3 layers

Aspetto	2 layers	3 layers
Complessità	minore	maggiore
Costo	minore	maggiore
Scalabilità	media	alta
Prestazioni interne	buone	migliori
Ridondanza	possibile	più strutturata
Adatta a	sedi medio-piccole	sedi grandi/campus
Spiegazione in esame	più semplice	più professionale
Big data interno	possibile, ma più delicato	più naturale
Molti edifici/piani	meno adatta	più adatta

6. Modello di descrizione da scrivere nella soluzione

Uno dei punti chiave delle griglie di valutazione qualità delle argomentazioni, e in generale il pensiero critico è una delle capacità di base in tutte le discipline, ha senso quindi inserire almeno descrizioni, una delle descrizioni da inserire **opportunamente personalizzata e arricchita di motivazioni e considerazioni critiche** (scelte ottimali non implicano soluzione perfetta, punti deboli e trade off fanno parte del pensiero critico) può essere:

“La rete viene progettata secondo un modello gerarchico, separando le funzioni di accesso, aggregazione, sicurezza, server farm, DMZ, management e collegamenti geografici. ... motivazioni Etc. ... Le VLAN permettono di isolare reparti, server, ospiti, dispositivi tecnici e traffico amministrativo. ... motivazioni Etc. ... Il traffico tra zone con diverso livello di sicurezza viene filtrato da firewall/ACL. ... motivazioni Etc. ... I servizi pubblici sono collocati in DMZ o nel cloud, mentre i database e i sistemi interni rimangono in reti protette. L'accesso remoto è consentito solo ai manager tramite VPN con autenticazione forte. La rete di management è separata e accessibile solo agli amministratori autorizzati. ETc. Etc. Etc. ”

7. Concetti/competenze elementari da avere necessariamente chiari

- differenza tra LAN, VLAN, DMZ, WAN, VPN, cloud;
- struttura access/distribution/core;

- struttura access/collapsed core;
- tipologie e casi d'uso dei firewall;
- tipologie e casi d'uso della DMZ;
- perché i database non vanno esposti direttamente;
- perché il guest Wi-Fi deve essere isolato;
- perché la rete di management deve essere separata;
- differenza tra VPN remote access e site-to-site;
- differenza tra server pubblici e server interni;
- differenza tra servizi on-premise e cloud, cloud serverless;
- utilità di IDS/IPS, NMS, logging e backup;
- requisiti di rete per cluster big data. (utile almeno per questo esempio)

Alcuni riferimenti

Cisco Campus LAN and Wireless LAN Solution Design Guide <https://www.cisco.com/c/en/us/td/docs/solutions/CVD/Campus/cisco-campus-lan-wlan-design-guide.html>

NIST SP 800-207 Zero Trust Architecture <https://csrc.nist.gov/pubs/sp/800/207/final>

CISA Zero Trust Maturity Model <https://www.cisa.gov/zero-trust-maturity-model>

AWS Direct Connect and IPSec VPN <https://docs.aws.amazon.com/wellarchitected/latest/hybrid-networking-lens/aws-direct-connect-and-ipsec-vpn.html>